

AI-DRIVEN API SECURITY MONITORING, INTELLIGENT THREAT DETECTION, AND AUTOMATED INCIDENT RESPONSE PLATFORM USING LARGE LANGUAGE MODELS

SOA Project Review-2

Thursday, September 24, 2026



Under the Guidance of

Dr. Srikanth Cherukuvada

Assistant Professor,

Department of Computer Science and Engineering,

KLH CSE Bowrampet Campus



Team Members

T. Aashritha Reddy - 2420030719

S. Indu – 2420030710

N. Sai Pragathi - 2420030672

Outline of Research Work

- Focus

- Introduction

- Literature Survey

- Challenges

- Research Objectives

- Conclusion & Future Work

- References

- Publications Details

Problem Statement

Existing API security solutions often rely on predefined rules, signatures, and isolated monitoring mechanisms, making it difficult to detect evolving, context-dependent, and previously unseen threats in real time. The lack of intelligent event correlation and contextual analysis can result in false alerts, delayed investigation, and inefficient incident response.

Therefore, there is a need for an AI-driven API security platform that continuously monitors API activity, intelligently identifies threats using behavioral analysis and Large Language Models, evaluates risk, and automatically initiates appropriate incident-response actions.

Objectives

- To develop a real-time API security monitoring platform.
- To detect abnormal and malicious API behavior.
- To use Large Language Models for contextual security-event analysis.
- To correlate API traffic, authentication events, logs, and threat indicators.
- To generate dynamic risk assessments for detected threats.
- To automate appropriate incident-response actions.
- To provide explainable security insights and incident reports.

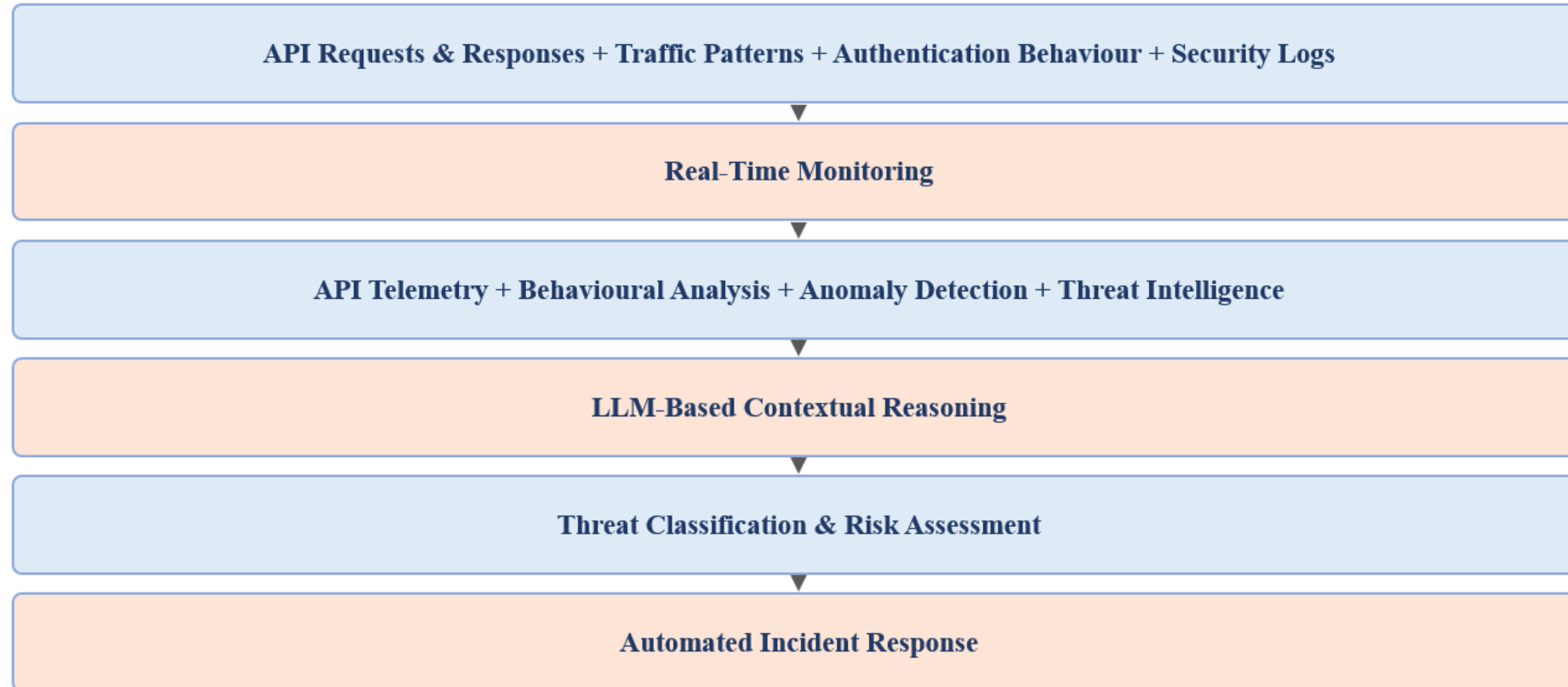
Literature Survey

Authors	Title of the Paper	Methodology	Inferences	Limitation/Future work
Baye et al. [2021]	API Security in Large Enterprises: Leveraging Machine Learning for Anomaly Detection	SVM-based binary classifier on API traffic features (bandwidth, requests per token)	Effectively distinguishes normal from abnormal API traffic using lightweight ML on traffic-level features	Limited to traffic/volume-based features; lacks semantic understanding of request content
Palma et al. [2025]	Leveraging Large Language Models for Scalable and Explainable Cybersecurity Log Analysis	Benchmarked open LLMs (Qwen2.5, Gemma3, Llama3.2) vs XGBoost/Random Forest/LightGBM with domain-specific prompt engineering	LLMs (F1 = 0.928) substantially outperform traditional ML (F1 = 0.555) and generate explainable, human-readable outputs	High compute cost for larger models; future work on real-time SOC pipeline integration
Ismail et al. [2025]	Toward Robust Security Orchestration and Automated Response in SOCs with a Hyper-Automation Approach Using Agentic AI	Agentic LLM-based SOAR generating AI-driven automation workflows aligned with the SANS PICERL framework	Improves flexibility and scalability of automated incident response over rigid no-code SOAR playbooks	Needs further validation on production-scale SOC workloads; future work on trust/safety of autonomous actions

Research Gap Identification

- Existing API security systems are heavily dependent on predefined rules and signatures.
- Conventional systems have limited contextual understanding of complex API behavior.
- Security events are often analyzed independently rather than correlated across multiple requests and sessions.
- Many systems focus on detection and alerting rather than automated response.
- Existing approaches may struggle with evolving and previously unseen attack patterns.
- There is limited integration of LLM-based contextual reasoning with real-time API security monitoring.
- There is a need for an integrated framework combining monitoring, intelligent detection, risk assessment, explainability, and automated response.

Proposed System / Methodology



Innovation, Creativity

- Unifies real-time API monitoring with LLM-driven contextual threat analysis.
- Incorporates intelligent multi-event correlation across sources.
- Provides explainable threat reasoning rather than opaque pattern matching.
- Performs adaptive risk assessment of detected threats.
- Integrates automated response within the same platform as detection.
- Detection and response are unified within a single cohesive platform, rather than treated as separate, loosely connected components as in conventional systems.



Novelty

- Real-time API monitoring detects suspicious activities continuously.
- AI-based behavioral analysis identifies abnormal and evolving attack patterns.
- LLM integration understands the context of security events and explains threats clearly.
- Threat correlation connects multiple security events to detect complex attacks.
- Dynamic risk assessment combines anomaly scores, threat indicators, and historical behavior.
- Automated response takes actions such as alerting, rate-limiting, blocking, and session revocation.
- Adaptive security responds according to Low, Medium, High, and Critical risk levels.
- Unified and proactive platform combines detection, analysis, explanation, risk assessment, and response.

Base Paper

AI-Driven API Security Monitoring, Intelligent Threat Detection, and Automated Incident Response Platform Using Large Language Models

T. Aashritha Reddy, N. Sai Pragathi, Seera Indu

Department of Computer Science and Engineering, K L (Deemed to be) University

Draft status note (delete before submission). Text in [square brackets] must be filled by the team. This draft contains no experimental numbers of our own. Sections XI–XIII are written so you can insert real results as you obtain them. Section IV describes ALERT based only on its published abstract; please check it against the full text before submission (see Section IV).

ABSTRACT

Web APIs now carry most of the business logic and data exchanged by modern applications, yet many API attacks are hard to detect because each individual request looks legitimate. Enumeration of resource identifiers, broken-object-level authorization abuse, credential attacks, and slow data exfiltration are visible mainly in the *sequence* of requests made by a session, user, or IP address. The recent ALERT framework (Sooksumrit, Wu, and Kanai, IEEE ICCE 2026) demonstrated a lightweight closed-loop SOC agent for web and API security that combines CVE severity prediction, runtime log anomaly detection, LLM-assisted semantics, cost-sensitive decision making, and ALLOW/MONITOR/BLOCK responses with a human in the loop. Building on that work, this paper proposes an API-focused, *behavior*-aware security monitoring and incident response framework that combines machine-learning-based anomaly detection with LLM-based contextual reasoning, explainability, risk assessment, and controlled automated response. Our two central extensions are (1) API-specific *behavioral* anomaly detection over session-, user-, and IP-level request sequences, and (2) API-specific graded incident response (monitor, rate limiting, temporary IP blocking, session/token revocation, endpoint restriction, administrator alert, and full blocking) selected by a transparent risk score under a policy engine that the LLM cannot override. The LLM is used for contextual reasoning, incident summarization, and recommendation, not as the detector. We describe the architecture, feature design, risk model, safeguards against prompt injection and unsafe actions, a Spring Boot/React/PostgreSQL implementation plan, and a full experimental methodology including an ALERT-style baseline. Empirical results are reported as future-in-progress work.

Keywords: API security; anomaly detection; large language models; incident response; risk scoring

I. INTRODUCTION

Application programming interfaces (APIs) are the main interface between clients, services, and data stores. The OWASP API Security Top 10 (2023 edition) lists authorization failures such as Broken Object Level Authorization (BOLA) and Broken Authentication among the most serious API risks [11]. Many of these attacks are *behavioral*; no single request contains a malicious payload, but the way requests are chained reveals intent. For example, a client that requests `/api/user/101`, `/api/user/102`, `/api/user/103`,

... `/api/user/5000` in quick succession is performing identifier enumeration, even though each request is syntactically valid and may return HTTP 200.

Recent research supports this observation. Yang et al. note that broken access control violations are often composed of multiple correlated requests that look normal in isolation [2], and Dong et al. describe “behavior-level” attacks that appear benign in individual flows but reveal malicious purpose across multiple flows [4]. At the same time, security operations *centers* (SOCs) face alert overload, which has motivated LLM-based alert investigation and triage [5], [8].

The base paper for this work, ALERT [1], is a 2026 IEEE ICCE contribution that presents a lightweight, CPU-only, closed-loop SOC agent with human-in-the-loop operation for web and API security. Its published abstract reports the combination of CVE severity prediction, runtime log anomaly detection, LLM-assisted semantics, cost-sensitive decisions, online policy adaptation, and ALLOW/MONITOR/BLOCK responses, evaluated on 10,000 synthetic Apache-style logs [1]. We explicitly acknowledge that ALERT already contains LLM assistance and automated (*closed-loop*) response.

Our contribution. This paper does not replace ALERT; it proposes an extension specialized for API traffic. We present:

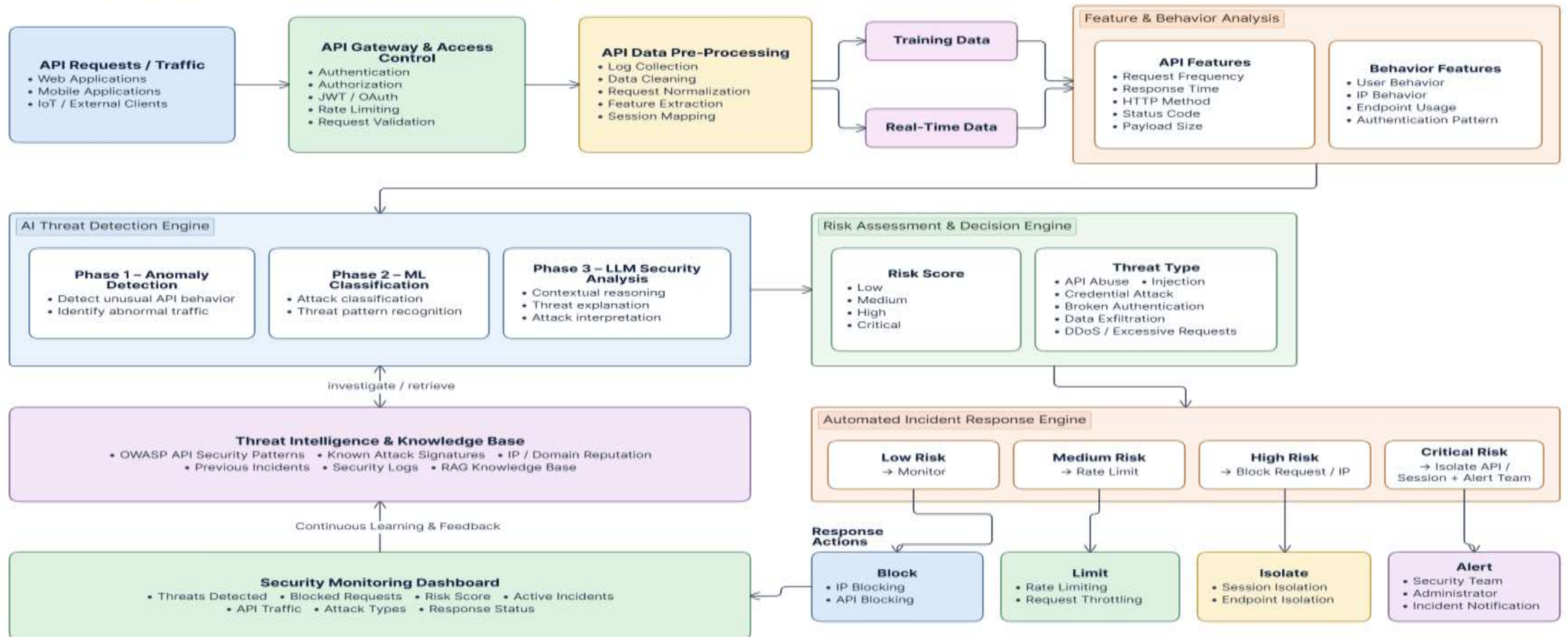
1. **API-specific *behavioral* anomaly detection** using request-, window-, and sequence-level features (endpoint template, method, identity, frequency, status codes, latency, payload size, endpoint sensitivity, repeated resource-ID access, call sequences, session *behavior*).
2. **API-specific intelligent incident response** with a graded action set (monitor, rate limit, temporary IP block, session/token revocation, endpoint restriction, administrator alert, full block) chosen from an API-specific risk score under a policy engine.
3. **A constrained LLM role:** contextual reasoning, event correlation, human-readable explanation, incident summarization, and response recommendation, with safeguards (structured prompts, output validation, restricted actions, data minimization, human approval, and prompt-injection *defenses*).
4. **A Spring Boot / React / PostgreSQL implementation blueprint and an experimental methodology** with ablations and an ALERT-style baseline.

Formally, our contribution is: *an API-focused, behavior-aware security monitoring and incident response framework that*

Project Architecture

Project Architecture / Project Overview:

AI-Driven API Security Monitoring, Intelligent Threat Detection & Automated Incident Response Using LLMs



Feasibility and Project Plan

Technical Feasibility

- API monitoring and logging
- Anomaly and behavioral detection
- LLM integration
- Security-event processing
- Risk-scoring mechanism
- Incident-response automation
- Security dashboard

Operational Feasibility

- Continuous monitoring
- Centralized security visibility
- Reduced manual investigation
- Faster incident response

Research Feasibility

- API security datasets/logs
- Simulated attack scenarios
- Security event generation
- Performance evaluation using detection and response metrics

Project Timeline

Phase 1	Phase 2	Phase 3	Phase 4
Problem Identification & Requirement Analysis Literature Survey & Research Gap Identification	System Architecture & Technology Selection API Monitoring & Data Collection Threat Detection & Anomaly Analysis	LLM-Based Security Analysis Risk Scoring & Threat Classification Automated Incident Response Module	Dashboard & System Integration Testing, Evaluation & Performance Analysis Documentation & Final Presentation